

Final Project Part 1

The Hospital, Part 1

You've been working in IT for a local hospital for two months. You'd rather be working directly in cybersecurity, but it helps pay the bills and gives you a little extra money for that vacation to Virginia Beach you've been saving for. Last week you learned that Tom, the lead cybersecurity engineer, will retire soon, and the entire hospital staff is throwing him a send-off party! Knowing that somebody has to fill Tom's spot, you think that now is a great time to buff up your resume and network with your colleagues.

At the party, you get to meet more of your coworkers from the hospital. Namely: Patricia, Wade, Omar, Derick, and Rachel. Each of them is the head/administrator of their department. You learn that Patricia is the lead paramedic, Wade is the lead project manager for web development, Omar oversees the other doctors, and Rachel is the head HR manager who also works in reception. As you're talking with Rachel, she begins to show you pictures of her newly adopted cat named after her favorite flavor of ice cream! After expressing your interest in Tom's position to Rachel, she's set you up with an interview spot next week. Score!

During your interview, you are welcomed by Rachel, Tom, and some other people in upper management. After introductions are exchanged, they begin to ask you questions such as: "Why do you want to work in cybersecurity?", "What is the CIA triad?", "What's the difference between encryption and hashing?" By the end of the interview, you're feeling confident that you've done an excellent job! You've been asked to wait in another room while the hiring staff talks amongst themselves for a couple of minutes.

After five or six minutes pass, you're brought back into the main meeting with the interviewers; Tom is the first to speak up. "I'm not entirely convinced you're exactly what we're looking for. Your passion for this profession is evident, but we're looking for somebody with a little more experience." Rachel chimes into the conversation and says, "However, due to how well you've done in your interview, we've come up with a proposition. We're due for an internal audit, and we're having a hard time finding a qualified person to pentest our systems. Suppose we give you a 'skills assessment' of sorts. If you can successfully locate and exploit vulnerabilities, read confidential data, recommend some remediations, and document the whole process, then we'd be convinced to move forward with your application."

After some more dialogue between Rachel and Tom, they agree to let you perform a partial pentest of the hospital as a 'skills assessment' portion of your interview. As per the pentest, you must sign a SOW, a Statement of Work, and a Non-Disclosure Agreement.

Statement of Work

Summary

This Statement of Work ("SOW") is between the Client (The Hospital) and the Contractor (You), effective the week of the Final Project Week 1

As of the Effective Date, this SOW is entered into by and between the Client and Contractor and is subject to the terms and conditions specified below. In the event of inconsistency between the terms of this SOW and the Agreement, the terms of the SOW shall prevail. This SOW between the parties is entered into in connection with an existing agreement between the parties. All terms used but not defined herein shall have the meanings outlined in the Agreement.

Purpose

The purpose of this SOW is agreed to by the parties as follows:

- (1) To conduct a network scan from the IP range of X.X.X.150-160.
- (2) To exploit only these specific IP addresses: X.X.X.150, X.X.X.156, X.X.X.158
- (3) To identify remediations and corrective actions for any vulnerabilities identified in Purpose (2)

Scope of Work

This SOW outlines the tasks and deliverables currently anticipated by the parties during the SOW term. Beginning the effective date, rules shall be set forth as follows:

1. The contractor may attempt to exploit vulnerabilities and gain access to *only three machines*, given that all exploits and vulnerabilities found must be thoroughly documented and reported to the client.
2. The contractor may look at any files accessed throughout the audit, given the condition that all sensitive information found is to be thoroughly documented and reported to the client.
3. The contractor may not be allowed to alter the integrity, availability, or permissions of patient and employee data throughout the audit. (i.e., no modifying or deleting healthcare documents, employment records, etc)
4. The contractor may not establish persistence.
5. The contractor will not be given usernames and passwords.
6. The contractor will be given physical access to the database.
7. The contractor may not disable or block any ports or services with the exception of Windows Server Messaging Block below Version 2.

Documentation for the Client:

Host discovery

You decided to map out the network along with the information you've learned from talking to your coworkers and from working in IT. There are five host machines in your scope of the pentest: an ambulance/ems laptop, a receptionist desktop, the clinician desktop, a database, and a web server.

Host Machines	Open Ports/Services	Operating System
Ambulance Laptop (X.X.X.158)		
Database (X.X.X.156)		
Web Server (X.X.X.150)		
Clinician Desktop (X.X.X.154)		
Reception Desktop (X.X.X.152)		

Exploiting the machines

As stated in the SOW, you must exploit these three machines: the Database, the Ambulance Laptop, and the WWW server. To do well on the skills test, you're expected to be able to break into each of the machines.

Machines	How did you gain access?	What specific harm could be done?	How can you remediate it?
Ambulance Laptop			
Database			
Web Server			

Sensitive information

As stated in the SOW, it is your responsibility to locate and document whatever sensitive data you can find on the Database, Ambulance Laptop, and the WWW server. This could happen during or after any of the other steps.

Host Machines	What Information I found, and why it's bad that I can see it.
Ambulance Laptop	
Database	
Web Server	

Remediation

The lead cybersecurity engineer is responsible for overseeing offensive operations (Pentesting and Red Teaming) and managing the protection and remediation of vulnerable systems. To do well in this stage of the recruitment process, you are expected to address any misconfigurations and vulnerabilities identified. You may attempt to remediate the issue. If you choose not to remediate, you must explain how you would go about remediating the problem.

Host Machines	For each vulnerability, misconfiguration, sensitive information disclosure, and malpractice answer the following: Does the issue need to be fixed? Why, or why not?	If actions were taken, how did you remediate it? If not, how would you remediate it?
Ambulance Laptop		
Database		
Web Server		

Turnin

You must copy the template provided and fill in the tables accordingly. Your lab report is **REQUIRED** to use the template below, or points will be taken away. You are expected to be very thorough in your answers. Vague descriptions or responses that don't correctly answer the questions from the table will receive zero credit. As a general rule, the more descriptive and informative your answer, the more likely you will receive credit. The less descriptive and uninformative your answer, the more likely it is that you will receive no credit. A good answer should be no less than two sentences.

An example of non-acceptable work:

Machines	How did you gain access?	What specific harm could be done?	How can you remediate it?
Machine X	I got access with RDP.	Because I could log in to the machine, I could do whatever I wanted with the user permissions.	Close the port

An example of acceptable work:

Machines	How did you gain access?	What specific harm could be done?	How can you remediate it?
Machine X	After running a port scan on machine X, I was able to find that Y service is open and running on port Z. After connecting to the port from my Kali box, I was able to gain RDP access without a password and login into machine X as user W. The command I used to perform this is [insert command].	Because I logged in as user W, I had access to the user's files, shared workspace, contacts, calendar, and more. Because I have access to this information, I would be able to sell this information, blackmail the employee, modify or steal information, create files, send phishing emails, and various other crimes.	Because I gained access through an open port 'Z' from an unknown machine, there are a few options. First, I could add a firewall to isolate people from the outside world from connecting to the machine. Second, it would be smart to add a password or even MFA to log in as the user. If all else fails, if the service is unnecessary, we can close the port.

Part 1 Template

(Note: the points for each row are given on an all-or-nothing basis. You must properly fill out each column in the row to receive all of the points. Properly filling out $\frac{2}{3}$ of the columns earns zero points. All of the fields in the row must be adequate to receive full credit for the given row.)

Host discovery (2 points per row; 10 total points)

Host Machines	Open Ports/Services	Operating System
Ambulance Laptop (X.X.X.158)		
Database (X.X.X.156)		
Web Server (X.X.X.150)		
Clinician Desktop (X.X.X.154)		
Reception Desktop (X.X.X.152)		

Exploiting three machines (10 points per row; 30 total points)

Host Machines	How did you gain access?	What <u>specific</u> harm could be done?	How can you remediate it?
Ambulance Laptop			
Database			
Web Server			

Sensitive information (10 points per row; 30 total points)

Host Machines	What information I found, and why it's bad that I can see it.
Ambulance Laptop	
Database	
Web Server	

Remediation (10 points per row; **30 total points**)

Host Machines	Vulnerabilities, misconfigurations, sensitive information disclosures, malpractices	Does the issue need to be fixed? Why, or why not?	If actions were taken, how did you remediate it
Ambulance Laptop			
Database			
Web Server			